



Analysing the role of LLMs in cybersecurity incident management

Gavin Jones¹ · Dimitrios Kasimatis¹ · Nikolaos Pitropakis² · Richard Macfarlane¹ · William J. Buchanan¹

Received: 27 June 2025 / Accepted: 19 October 2025 / Published online: 30 October 2025
© The Author(s) 2025

Abstract

Cybersecurity and artificial intelligence (AI) increasingly intersect as organizations grapple with sophisticated cyber threats and expanding digital landscapes. Incident response teams traditionally rely on structured procedures to identify, manage, and mitigate cyber incidents. Our work explores the effectiveness of generative AI, specifically Large Language Models (LLMs), within cybersecurity, focusing primarily on incident response processes. Experimental evaluations demonstrate that specific LLMs exhibit distinct strengths suitable for different stages of incident management. GPT-4o and GPT-3.5 show high clarity, consistency and coherence, making them appropriate for real-time containment, isolation, eradication and recovery tasks. Conversely, models such as GPT-o1 and GPT-4 offer superior reasoning capabilities and conciseness, better supporting incident preparation, post-incident analysis, vulnerability assessment and training development. Key limitations pertaining to current LLM implementations are identified, particularly token context constraints in addition to a discussion about ethical considerations regarding reliance on AI responses, including potential impacts on workforce skills and organizational security posture.

Keywords Large language models (LLMs) · Artificial intelligence (AI) · Incident response · AI ethics

1 Introduction

Cybersecurity and artificial intelligence (AI) are two rapidly evolving areas driven by significant technological advances and increasing reliance on digital infrastructure [1]. Organisations face persistent challenges in managing cybersecurity threats due to the continuous sophistication of cyber-attacks and expanding digital surfaces. Given the growing risk of cybersecurity incidents significantly affecting organizations and their customers, cyber defences must continually evolve,

requiring exploring new approaches to incident and threat management [2].

Incident response teams are responsible for following processes to detect, manage and remediate organisational incidents. Recent developments in generative AI, particularly Large Language Models (LLMs), are promising avenues for enhancing these processes. LLMs trace their foundations back to Alan Turing's early work in machine intelligence and his unpublished paper titled *Intelligent Machinery* [3]. Turing theorised machines capable of imitating human-like reasoning sufficiently well to deceive human interrogators, laying the groundwork for modern AI research.

Today, LLMs, as an advanced form of generative AI, are becoming increasingly popular within cybersecurity operations, particularly in incident response scenarios. These models can go through analysis of large amounts of data in a short time span, enabling insights and responses to cyber-incidents that are not possible with traditional approaches. However, using LLMs raises various concerns over the reliability and accuracy of the responses. In addition, there are potential ethical implications to using AI tools, and regulation surrounding them is still in its infancy, with supranational organizations like the EU adopting the *EU AI Act* of 2024 [4].

✉ Dimitrios Kasimatis
d.kasimatis@napier.ac.uk

Gavin Jones
40204102@live.napier.ac.uk

Nikolaos Pitropakis
npitropakis@acg.edu

Richard Macfarlane
r.macfarlane@napier.ac.uk

William J. Buchanan
b.buchanan@napier.ac.uk

¹ School of Computing Engineering & the Built Environment, Edinburgh Napier University, Edinburgh, UK

² Department of Information Technology, The American College of Greece, Athens, Greece

To address the challenges and opportunities presented by generative AI in cybersecurity, this paper offers the following key contributions:

- Assesses the effectiveness of generative AI and LLMs with a focus on incident response.
- Experimentally evaluates the practical applicability of generative AI in managing cybersecurity threats.
- Address concerns of LLM usage related to accountability and ethics.

The rest of the paper is structured as follows. Section 2 establishes background knowledge based on academic sources on the technologies and methods discussed throughout the paper. Section 3 critically reviews related academic studies to our topic. Section 4 outlines the methodology of the experimental setup, the testbed, and the evaluation metrics. Section 5 presents the experimental results that were derived from the tests. Section 6 reflects on the practical outcomes of the results, while also pondering the ethics. Finally, Section 7 summarizes the outcomes and contributions of the study and presents suggestions for future work.

2 Background

2.1 Incident Response

To protect the confidentiality, integrity, and availability of information, organisations typically allocate substantial resources to developing robust cybersecurity measures. These measures form protective barriers intended to prevent cyberattacks from impacting organisational assets. Common strategies include establishing comprehensive risk management policies, developing procedural guidelines, conducting regular employee training, and deploying technological defences such as firewalls, intrusion detection systems (IDS), and layered encryption methods [5]. One of the critical components within this broader cybersecurity approach is the incident response process.

Incident response is a formulated approach used by organisations to detect, manage and mitigate the impacts of cybersecurity incidents. Effective incident response aims to minimise disruption, limit damage, and facilitate rapid recovery. Organizations commonly adopt a structured incident response model, typically consisting of five sequential phases [6]:

1. **Preparation** phase involves establishing defences, processes and teams in anticipation of potential cybersecurity incidents.

2. **Detection and Analysis** phase is where the incident is identified and verified, and the scope and impact are assessed.
3. **Containment** phase aims to limit the spread and immediate effects of the threat.
4. **Eradication** phase involves removing the threat and any related malicious components entirely.
5. **Recovery** is the final phase that focuses on returning organizational operations to normalcy and reviewing the incident to identify lessons learned to improve future responses.

Although the linear approach to incident response described above is widely adopted, it has inherent limitations, particularly when addressing complex or sophisticated cyberattacks. Its sequential nature can lead to delays, reducing the organization's ability to respond rapidly and effectively [7]. As cyber threats become increasingly advanced and targeted, traditional linear incident response methods may fail to adequately manage incidents, highlighting the necessity for ongoing adaptation of cybersecurity strategies to match the pace and complexity of evolving threats [8].

2.2 AI within Cybersecurity

Generative AI refers to computational methods that learn from extensive datasets to produce new, contextually relevant content. This output may include text, images, audio, or video. Recent developments such as GPT-4, DALL-E, and GitHub Copilot are beginning to reshape practices across various industries [9]. Among these, ChatGPT has become one of the most notable examples due to its advanced language capabilities and widespread public use [10]. These systems are powered by LLMs, which fall within the broader category of foundation models. A foundation model is trained on a wide variety of data using self-supervised learning techniques and is designed to be adapted for different tasks and media types [11]. LLMs focus specifically on language and are capable of generating human-like text in response to input prompts [12]. Although LLMs became widely recognised following the release of ChatGPT in 2022, their foundations lie in earlier research on neural networks and machine learning (ML). Recent progress has been driven by increases in model size and computing power. For example, GPT-3 contains 175 billion parameters [13], while GPT-4 is believed to contain significantly more, though its exact size has not been confirmed.

AI, particularly through ML, is increasingly used in cybersecurity to automate tasks such as threat detection, anomaly recognition, and intrusion response [2, 14]. While organizations adopt these tools for defensive purposes, threat actors are also employing ML to develop more evasive malware.

One example is IBM's DeepLocker, which uses AI to conditionally trigger attacks based on attributes such as facial recognition or geolocation [15]. Recent work has investigated the role of LLMs in secure software development. Noever [16] compared OpenAI's GPT-4 vulnerability detection capabilities with a rule-based static code analyzer, Snyk. GPT-4 identified 393 vulnerabilities in a benchmark codebase, compared to Snyk's 98. In addition, GPT-4 proposed 398 code corrections, one for nearly every issue identified. The manual inspection found a low false positive rate, with 4 out of 60 reviewed cases incorrectly flagged in an earlier version of the model.

Noever's study also assessed the impact of these LLM-generated fixes. When GPT-4's corrections were applied, high-severity vulnerabilities were reduced by 94%, medium by 75%, and low by 92%, resulting in a decrease from 98 vulnerabilities to 10. These corrections increased the codebase by only 11% in terms of lines of code, suggesting a relatively low cost for mitigation. While these results indicate strong potential for LLMs in vulnerability detection and remediation, limitations remain, particularly with system-level dependencies and context beyond small code snippets.

Overall, AI and LLMs present valuable opportunities for supporting secure development practices. However, their outputs must be critically assessed, and further research is needed to improve reliability, reduce false positives, and extend capabilities to more complex software environments [17].

The effectiveness of LLMs is influenced not only by their underlying algorithms and training data but also by how inputs, known as prompts, are constructed. Prompt engineering involves developing clear and structured prompts that guide the LLM towards generating relevant and accurate responses [18]. Effective prompts are typically concise, logically structured, explicitly state the desired outcome, allow flexibility for adjustments, and involve reviewing previous results to identify improvements.

In addition to prompt phrasing, technical settings such as token limits, temperature, and top-p affect the output of LLMs. Tokens refer to units such as words or characters processed by the model [19]. Temperature and top-p settings control the randomness of the model's outputs, influencing the predictability and specificity of generated responses [20].

A key limitation of LLMs and, by extension, prompt engineering is their tendency to produce incorrect or fabricated information, commonly referred to as hallucinations. This issue arises partly from the static nature of their training data and the inability of models to update or expand their knowledge base dynamically [21]. One method for reducing hallucinations is retrieval-augmented generation (RAG). RAG supplements model outputs with additional context from external, up-to-date information sources. This approach

improves response accuracy by providing context-specific data to guide the LLM's outputs.

However, RAG is not a complete solution, as its effectiveness depends on the accuracy of external data sources [22]. Furthermore, the inherently probabilistic nature of LLMs means their outputs cannot be fully guaranteed [23]. Despite these limitations, retrieval-based techniques are still being considered by the research community as one of the most effective ways to reduce hallucinations and thus improve LLM accuracy, as evidenced by the study conducted by Cuconasu et al. [24].

3 Related work

Recent research has explored the potential of LLMs to enhance incident response planning (IRP), particularly in cybersecurity contexts. Hays and White [25] emphasise the complexity and challenges inherent in traditional IRP processes, notably in maintaining plan relevance, consistency, and adaptability in dynamic threat environments. The authors propose integrating LLMs to streamline IRP creation and review by leveraging frameworks such as SMART (Specific, Measurable, Achievable, Relevant, Time-bound) and introducing semantic versioning to manage document freshness and consistency between IRPs and standard operating procedures (SOPs). The paper argues for LLMs' ability to clarify ambiguous tasks, visualise process flows, perform gap analyzes, and assist in retrospective analyzes following security incidents. However, while the study highlights significant benefits, including improved efficiency and proactive planning, it acknowledges critical limitations, such as data privacy risks and the potential pitfalls of dependency on automation. A notable gap in the study is the absence of empirical validation, as the effectiveness of proposed LLM-supported strategies has not been explicitly demonstrated through quantitative or qualitative means.

In contrast, research by Liu Z. [26] investigates the application of LLM-based agents for supporting incident response through multi-agent collaborative frameworks, using the cybersecurity tabletop exercise Backdoors & Breaches as a testbed. Their study demonstrates how generative AI can facilitate tasks such as planning, decision-making, and investigation within structured incident scenarios, highlighting benefits such as improved automation, reasoning, and coordination among AI-driven agents. These findings align with the existing literature, which highlights the potential of generative AI to enhance responsiveness and systematic planning during cybersecurity incidents. However, while the author effectively illustrates the collaborative capabilities of LLM agents, their evaluation remains limited to controlled tabletop exercises, limiting insight into how these methods might perform under realistic incident conditions. Furthermore, the

paper provides limited exploration into the practical considerations regarding reliability, accountability, and ethical implications associated with the operational use of LLMs.

4 Methodology

4.1 Experimental Setup

As our goal was to investigate and measure the effectiveness of LLMs when faced with a cybersecurity incident, a tool was developed to serve as an incident response assistant or copilot. This tool took an input supplied by a user which contained certain details about the incident that was ongoing, and the LLM was instructed to provide response actions the user should take in order to mitigate the incident.

To allow running the program multiple times across various LLMs without extensive manual input, we properly enhanced our tool by allowing programmatic input. The latter also enabled extensive experiments that will be detailed as well as the ability to measure its effectiveness.

Several real-world examples of highly impactful cybersecurity incidents were supplied to the chosen LLM. The scenarios were created under differing settings, thus evaluating how effectively the LLM can respond to them.

Our settings were influenced by the research structure of OpenAI where an LLM is measured under “Few shot”, “One shot” and “Zero shot” context conditions with several examples, one example and no examples respectively, when being provided a task to carry out [27]. Ten real-world incident scenarios were evaluated using four OpenAI ChatGPT variants, namely gpt-3.5-turbo, gpt-4-0125-preview, gpt-4o and o1-preview. Each scenario was run under the three context conditions and repeated ten times for each condition to average stochastic variability, producing 1,200 model invocations in total. Scenarios were selected to maximise external validity and reproducibility. They represent high-impact and prevalent incident classes so that results reflect enterprise conditions. They map across the NIST 800-61 lifecycle to avoid bias toward a single phase. They span diverse attack vectors and environments, for example volumetric denial of service, cloud data exfiltration, insider misuse, ransomware with lateral movement and web application compromise across cloud and on-premise settings with both internal and external threats, allowing observation of model behaviour across contexts. Each scenario was specified in two variants, a baseline version and an enriched version, to test sensitivity to added context and to align with the zero-shot, one-shot and few-shot regimes.

These models were chosen to cover distinct capability profiles relevant to incident response while keeping provider infrastructure constant. GPT-3.5 serves as a widely deployed and lower-cost baseline. GPT-4 is a higher-capacity gen-

eral model with stronger instruction-following capabilities. GPT-4o is optimized for speed and interactive use, which is pertinent to time-critical containment and recovery. GPT-o1 is designed for stronger reasoning and supports multi-step analysis in preparation, post-incident review and vulnerability assessment. Using a single provider ensured consistent APIs, safety controls and logging, which reduced confounds unrelated to model capability. The models were used “as is” via the OpenAI API. Default configuration parameters, including temperature, top-p, and maximum tokens, were not overridden. This ensured that all model variants were evaluated under identical and reproducible conditions that reflect typical practitioner use. The LLM’s responses were measured in the above fashion individually and an average across each response and metric was taken. Without replicating the referenced approach, ours was structured as follows:

1. **Level 1: Without a runbook (known in research as “zero-shot” [27]):** The LLM responds to the incident based on the user’s input and the prompt wrapper, which remains consistent throughout the experiment. There is no predefined runbook or guidance supplied as part of the prompt, the LLM will rely solely on the pre-trained knowledge when providing reasoned actions. The LLM will be given a scenario which it will be instructed to answer. For example:

Prompt: *You are a cybersecurity incident response manager. Answer the following question.*

Answer: *Alarms have been triggered indicating that our external facing AWS endpoints are being hit by a DDoS attack. How do we respond?*

Purpose: To establish a baseline of how effectively each model can respond to an incident without any structured guidance or contextual support, relying solely on pre-trained knowledge and the base prompt telemetry needed for verification.

2. **Level 2: With a generalized runbook:** The incident is run with a standard incident response runbook taken from the guidelines outlined in the Computer Security Incident Handling Guide [6], this is a widely used framework that outlines broadly how an incident should be handled. For example:

Prompt: *You are a cybersecurity incident response manager. Answer the following question.*

Context: *You will follow the NIST standards guideline on how to respond to a cyber security incident:*

Preparation: *Establish and maintain incident response capability.*

Detection & Analysis: *Detect, analyze logs, classify incidents, and gather evidence.*

Containment: *Implement containment strategies and isolate affected systems.*

Eradication: Eliminate components of the incident, identify the root cause.

Recovery: Restore systems, validate with testing, monitor for remaining issues.

Post-Incident Activity: Review, update policies, and document lessons learned.

Answer: We have evidence that an unauthorised threat actor has infiltrated our public-facing S3 buckets and has managed to steal a significant amount of customer personal information. What do we do?

Purpose: To measure the effectiveness of the LLMs response when presented with a general runbook, allowing for flexibility in responding to the incident scenario. The measurable criteria is by how much the answers have gotten better or worse than when zero shot is used.

3. **Level 3: With examples of how previous incidents were handled and what went wrong before:** The LLM will be provided with the runbook in level 2, but also will be provided with the knowledge on how this kind of incident has been handled in previous occurrences. For example:

Prompt: You are a cybersecurity incident response manager. Answer the following question.

Context: You will follow the NIST standards guideline on how to respond to a cyber security incident:

Preparation: Establish and maintain incident response capability.

Detection & Analysis: Detect, analyze logs, classify incidents, and gather evidence.

Containment: Implement containment strategies and isolate affected systems.

Eradication: Eliminate components of the incident, identify the root cause.

Recovery: Restore systems, validate with testing, monitor for remaining issues.

Post-Incident Activity: Review, update policies, and document lessons learned.

Extra information: Previously, this issue was contained by immediately isolating the affected system from the network, ensuring the system is remotely locked down using MDM tooling and asking the employee to bring the device into the office.

Answer: We have evidence of an insider threat leaking vast amounts of information which was later found on a .onion website forum. At this point we are unsure if they are deliberately doing this themselves or whether the machine is compromised by an external threat actor.

Purpose: To test the LLM's effectiveness in response when given a structure on how to respond as well as what previous actions were taken when the incident happened before.

4.1.1 Prompting

The base prompt used for these experiments was an important factor in obtaining robust results with as little ambiguity and irrelevance as possible. The prompt across all of these experiments, thus, remained consistent with the exception of gradual addition of context. The prompt was developed in conjunction with the CLEAR framework [28]. The following prompt served as a prompt wrapper to run the experiments:

"You are a cybersecurity incident response professional. You are tasked with responding to this specific incident using all available guidelines, knowledge, and tools. Provide actionable steps on how to respond to the incident, prioritizing mitigation of the impact as quickly as possible. Your response should be clear, concise, and organized around key response actions. Tailor your response to the incident details provided."

4.2 Testbed Setup

4.2.1 Design and Architecture

To test the responses thoroughly, the scenarios mentioned below in section 3.3.4 would be run against a set number of chosen Large Language Models. The chosen models were all developed by OpenAI:

- **gpt-3.5-turbo:**

- Release date: November, 2022
- Knowledge cutoff (at time of writing): September 2021

- **gpt-4-0125-preview:**

- Release date: January, 2024
- Knowledge cutoff (at time of writing): December, 2023

- **gpt-4o:**

- Release date: May, 2024
- Knowledge cutoff: October 2023

- **o1-preview:**

- Release date: September 2024
- Knowledge cutoff: October 2023

Our program's architecture took the form of a client-server model. The specifications of the machine used for the experiment are: Macbook Pro with an M1 Max Central Processing Unit (CPU), housing 64GB RAM. The scripts run locally as the client, and OpenAI's cloud API environment acted as the server. The code was designed in such a way that the scenarios were pre-written and subsequently taken from a

JSON file, wrapped in a prompt, then supplied to the LLM via an API interface connecting to OpenAI's cloud environment. The interactions were all logged and outputted to an XML file which was later turned into an XLSX file for ease of access with programs such as Excel and Google Sheets. The python library logging was also used as a debugging and program flow monitoring effort.

4.3 Measuring the response

During our performed experiments, the algorithm remained consistent, thus maintaining the same code during the different scenarios. As mentioned previously, we used as variables a) the level of the context of the LLM and b) the LLM model.

To measure the effectiveness of the LLM's capabilities in these different incident scenarios, it was required to find metrics that could adequately determine the effectiveness of the LLMs responses. Thus we used a combination of quantitative and qualitative metrics that will be discussed next.

4.3.1 Quantitative

Consistency: BERTScore will be used to find the consistency of responses. BERTScore is based on the pre-trained language model BERT which was developed by Google and enables the measuring of semantic equivalence by computing the similarity between sentences as a sum of their cosine similarities between their tokens embeddings [29]. It allows for a score between 0 and 1, which is calculated as an average of the scores retrieved for each stage and LLM used across 10 iterations of the same incident scenario. When responding to incidents, it is utterly important for the response actions to be consistent and follow a defined routine [30].

Conciseness: The aim of measuring conciseness in a response is to determine its brevity and succinctness, thus evaluating how well the LLM can convey the required information without adding unnecessary verbosity. Within incident response, clear information is important to act quickly without extra padding around the wording as that may lead to prolonged mitigation.

Conciseness will be measured using an open source python library called spaCy which is used for advanced natural language processing as it provides several important features such as tokenization, text analysis and Part-of-speech (POS) tagging [31]. The spaCy library tokenises the text, decides where the sentence starts and ends, then assigns each token a POS tag. The tokens are filtered, and then we use spaCy's tagger tell us which words are linking words. Both metrics are divided by the sentence count, so that longer answers are not automatically penalised. The average length of the response sentences was then taken and put into a graph. The lower the score, the more concise the response.

Coherence: For coherence, the spaCY library will also be used in order to measure the logical flow and consistency in the response given by utilising natural language processing techniques to look at sentence structure and count occurrences of specific linking words (cohesive devices). Cohesive devices will be identified dynamically using POS (Part-of-Speech) tagging within the function based on their grammatical roles (such as conjunctions and prepositions). The coherence score will also be worked out as an average of the cohesive devices and the total number of sentences. Higher scores here indicate an increased use of transition-ing words and conjunctions suggesting a better logical flow. Using this logic, the way this is measured is by counting the number of cohesive devices within the span of text, the output is then presented on a graph.

4.3.2 Qualitative

There are several possible options for measuring qualitative results.

Our approach of judging these answers was chosen because it has adopted recently by the industry to judge the response capabilities of an LLM. This method is called "LLM-as-a-judge" [32] and provides an LLM (in this case, ChatGPT's 4o model for all responses) with criteria and context to judge the provided responses. Each criterion followed a base prompt outlined below.

Base prompt: *You are assigned with judging the above responses to cyber security incidents based on the provided scenario and the reference answer.*

The responses are taken from an LLM when provided with a scenario and the following prompt: You are a cybersecurity incident response professional. You are tasked with responding to this specific incident using all available guidelines, knowledge, and tools. Provide actionable steps on how to respond to the incident, prioritizing mitigation of the impact as quickly as possible. Your response should be clear, concise, and organized around key response actions. Tailor your response to the incident details provided.

You will judge the response given based on each of the following metrics from a scale of 1 through to 10.

The reference above is a retrospective from a similar incident and should be taken as a guide for your judgement only as it was based on a similar incident. The reference will likely have more answers than the response. The answer are not expected to be the same and should be judged based on the below criteria.

As an expert evaluator, provide objective assessments using the full range of the scale. Be critical and discerning in your judgments to reflect the true quality of the response.

Note that a score of 10 represents an exceptional standard and should only be awarded when the response fully meets the highest criteria described.

Please ensure that your evaluations strictly follow the criteria outlined for each scale, without leniency or bias.

Relevancy: Relevancy was measured on a scale of 1-10, according to how relevant were the response actions proposed.

The following scale was used to measure relevancy:

- 10: Highly pertinent response, directly addressing all aspects of the incident with tailored actions.
- 9: Very relevant, covering most incident specifics with minor generalizations.
- 8: Relevant response, addressing key incident elements with some general advice.
- 7: Generally pertinent, with a balance between specific and generic actions.
- 6: Moderately relevant, focusing on common incident aspects with limited specificity.
- 5: Some relevance, addressing general incident response without tailoring to specifics.
- 4: Limited pertinence, with a predominantly generic approach.
- 3: Minimal relevance, with few connections to the specific incident.
- 2: Barely pertinent, with negligible consideration of the incident's context.
- 1: Irrelevant response, failing to address the incident appropriately.

Clarity: The clarity of response is also measured on a scale of 1-10.

The following scale was used to measure clarity of responses:

- 10: Exceptionally clear and concise, with precise language and no errors.
- 9: Very clear, with minor errors that do not impede understanding.
- 8: Clear communication, with occasional errors that slightly affect clarity.
- 7: Generally understandable, with some errors that may require clarification.
- 6: Moderately clear, with errors that somewhat hinder comprehension.
- 5: Basic clarity, with frequent errors affecting understanding.
- 4: Limited clarity, with numerous errors making comprehension difficult.
- 3: Poor clarity, with pervasive errors severely impacting understanding.
- 2: Very poor clarity, with errors rendering the response nearly incomprehensible.
- 1: Unclear and confusing, with errors that make the response unintelligible.

Domain-specific terminology: The response should be using language that resonates with cybersecurity professionals that are attempting to respond to the incident, and not ambiguous or irrelevant language. This metric was also measured on a scale of 1-10 and the following scale was used to measure domain-specific terminology:

- 10: Expert use of precise, domain-specific terminology, demonstrating deep understanding.
- 9: Advanced use of technical terms, with minor inaccuracies.
- 8: Proficient use of relevant terminology, with occasional misuse.
- 7: Competent use of technical language, with some errors.
- 6: Adequate use of domain-specific terms, with noticeable inaccuracies.
- 5: Basic use of technical terminology, with frequent errors.
- 4: Limited use of appropriate terms, with significant inaccuracies.
- 3: Minimal use of domain-specific language, with pervasive errors.
- 2: Very limited technical terminology, with substantial inaccuracies.
- 1: No use of relevant terminology, demonstrating lack of domain knowledge.

Logical Coherence (from an LLM): Measured on a scale of 1-10, this metric aims to determine whether the response is logically structured and coherent and understand the differences between the NLP measurement of coherence versus the LLM output.

The scale used to determine logical coherence is as follows:

- 10: Exemplary structure, adhering strictly to industry-standard frameworks such as NIST's Incident Response Lifecycle: Preparation, Detection and Analysis, Containment, Eradication, Recovery, and Post-Incident Activity. (NIST Cybersecurity Framework)
- 9: Nearly perfect structure with minor deviations that do not impact overall coherence.
- 8: Strong adherence to standard frameworks with slight inconsistencies.
- 7: Good structure, following most industry-standard phases with occasional lapses.
- 6: Adequate organization, covering key phases but missing some elements.
- 5: Moderate coherence, with noticeable gaps in the incident response phases.
- 4: Basic structure present but lacks depth and completeness.

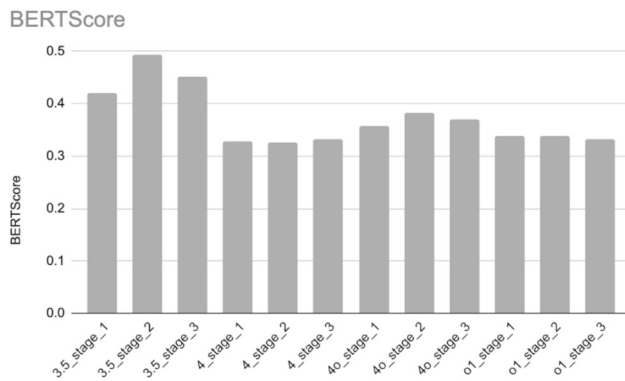


Fig. 1 Results: BERTScore graph

3: Poor organization, with significant omissions in the response process.

2: Minimal structure, failing to follow recognized incident response phases.

1: No logical structure, with a disorganized and fragmented response.

5 Experimental results

The results were collected and averages worked out for each of the criterion mentioned within the methodology. The summary table outlining the results can be found in Appendix A.

Initially, the quantitative metrics of consistency, Table 1 i.e. BERTScore, conciseness and coherence will be analyzed, followed by the qualitative subjective metrics of Clarity, Relevance, Domain-specific Terminology and Logical coherence. The breakdown of each metric will highlight notable areas such as the highest and lowest scoring results, trends in the data, expected results in comparison to the actual results, and some will look deeper into sample data Fig 1.

5.1 Quantitative metric comparison

5.1.1 BERTScore

The goal of measuring the BERTScore was to observe how consistent the responses were. The score is measured between 0 and 1, a very consistent response being closer to 1. To showcase the difference, the scale within the graph was reduced from 0-0.5. The results above illustrate the different models across the different levels of context granted. From these results, GPT-3.5 performed better than all of the other models even when granted the least amount of context (stage 1) scoring up to 4.9. The most consistent results came from GPT-3.5 with stage 2 level of context granted which is somewhat surprising that when given extra context and a dedicated runbook, the answers were not as consistent. The next

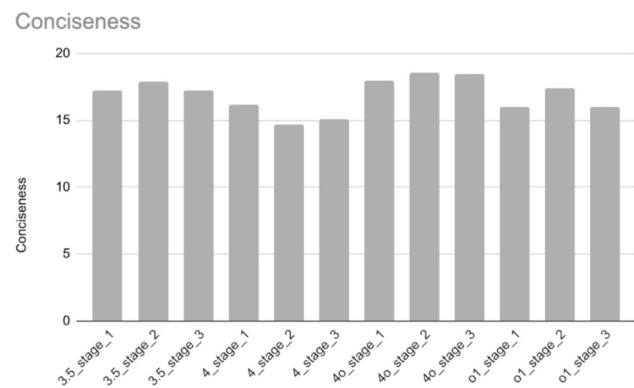


Fig. 2 Results: Conciseness graph

best results in consistency came from the GPT-4o model at an average of 3.7, followed by GPT-o1 at 3.3 and then lastly GPT-4 at 3.2. What is apparent was when provided with stage 2 level of context meaning the generic runbook, the results were better for all of the models besides GPT-4. An interesting note is that the response given from the model that had the least amount of pre-trained data was also the most consistent in terms of the answers granted, while the most inconsistent responses were very close between the model with the most and second most amount of pre-trained data.

5.1.2 Conciseness

For this scale, a lower score indicates that the response is more concise. GPT-4 on average responds the most concisely, especially under the conditions of stage 2 context level resulting in 14.6 words per sentence. After this, GPT-o1 responds the second most concisely with 15.9 words per sentence, followed by GPT-3.5 with 17.2, then GPT-4o with around 18. What should be observed is the most concise responses came from Fig 2 stage 2 against the GPT-4 model, but stage 2 was the least concise response from all of the other GPT's that were tested against. What is notable here is there is no discernible trend between pre-training data and conciseness as the most and second most concise models were GPT-4 and GPT-o1, while the third and fourth came from GPT-3.5 and GPT-4o.

5.1.3 Coherence

When interpreting the level of coherence, a higher score above indicates more conjunctions and transitioning words, indicating a more logical flow. The results here show that GPT-4o at stage 3 level of context proved to be the most coherent with 27.6 cohesive devices within the span of text, and also consistently coherent across all the stages as well. This is the same for GPT-3.5 where the results show that it was also measuring consistently high coherence levels at

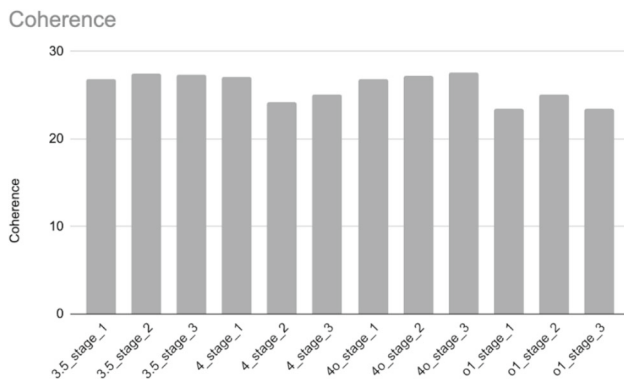


Fig. 3 Results: Coherence graph

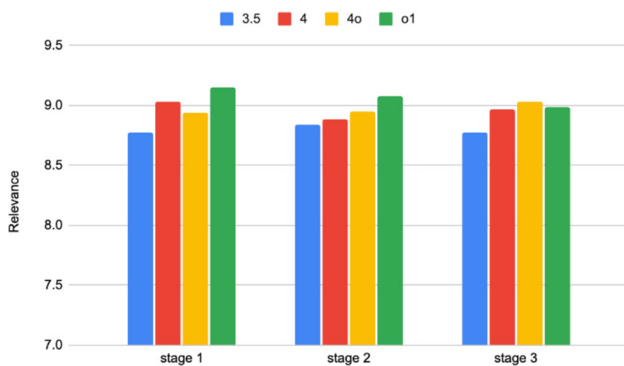


Fig. 4 Results: Relevancy graph

around 27.3. The least coherent somewhat surprisingly was GPT-o1 at an average of around 24, which shows that this model was scoring rather low in comparison to the others, and was only just higher than GPT-4 across stage 2 testing with just above 25 on average. What is notable though is how this graph looks quite similar to the conciseness graph above. The results here have flipped, in that GPT-4o and GPT-3.5 are at similar levels and are portrayed to be the most cohesive. It is optimal in incident response Fig 3 to maintain a logical structure and flow in the output to ensure it is readable and understandable, but this should not come at the expense of conciseness by adding unnecessary verbosity.

5.2 Qualitative metric comparison

As stated within the methodology above, the following metrics were taken from LLM as a judge. The goal of this way is to attempt to measure the responses utilising new methods and ways of judgement.

5.2.1 Relevancy

Measured on a scale of 1 through 10, the higher the results were, the more relevant they were in accordance with the criteria provided. In order to see the difference in response more

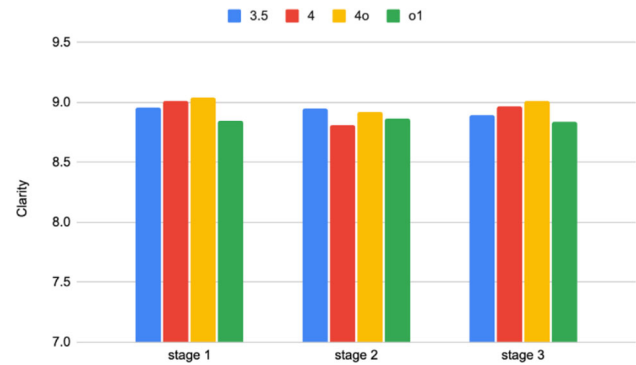


Fig. 5 Results: Clarity graph

clearly, the graph was shortened to the range of 7-10. GPT-o1 proved to show the best results across the board in stage 1 level context at just above 9.1 on average across the testing scenarios. In general, the results follow a somewhat expected pattern in that the Fig 4 models with higher training data are providing the most relevant results. This is especially apparent in stage 1 level context where the latest model with the most recent knowledge cut-off date came out as the highest performer. Unsurprisingly, GPT-3.5 performed the worst across the board at 8.7, but considering the shortened graph, there is not a huge difference here. The overall expectation would be that the latest models scored higher than the rest, but in general seeing as these models are trained on exponential amounts of data and have all been released quite recently, all the models should be able to contextualise their response adequately enough.

5.2.2 Clarity

Measured on a scale of 1 through 10, it can be observed that on average, GPT-o1 performed the worst out of all of the models across this test resulting in a score of 8.8, the best performer being the GPT-4o model at above 9 in stage 1 and 3. The results were all very close again, so the scale on the graph was shortened to see ease in the effort of observing differences in the level of response. The most consistent in clarity of response came from GPT-3.5 at 8.92 and GPT-o1 at 8.84. The best response on average was observed from GPT-4o. On further observation and analysis of the results, the expectation would be that these are similar to that of the conciseness and coherence measurements earlier, and GPT-4 did score well here Fig 5.

5.2.3 Domain specific terminology

Domain-specific terminology was attempting to measure as to what competence language level the LLM was able to respond and guide a cybersecurity professional. The response was measured on a scale of 1 through 10, and the graph was

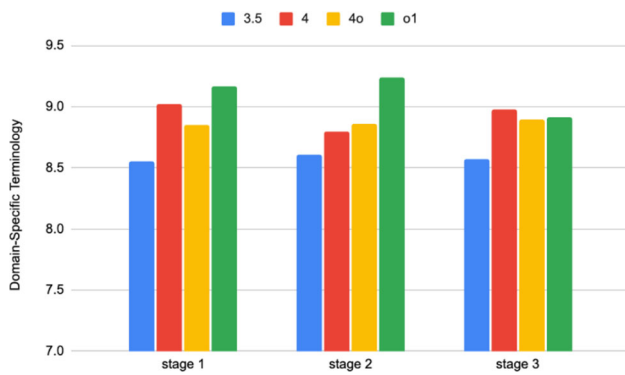


Fig. 6 Results: Domain-specific terminology graph

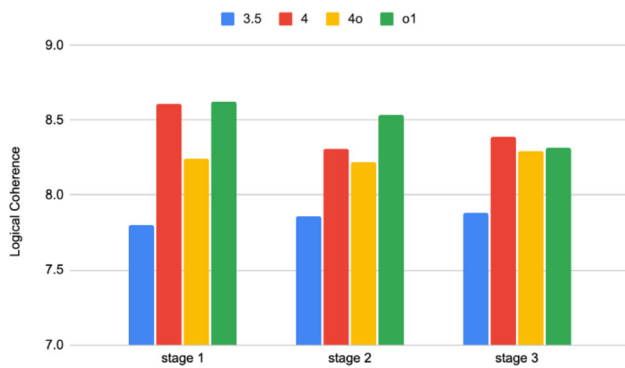


Fig. 7 Results: Logical Coherence (LLM) graph

shortened so as to aid in observation. The GPT-o1 model in this case performed at a consistently high rate, scoring the highest results across the board in stage 1 and stage 2 at 9.1 and 9.2 respectively. Interestingly when supplied with stage 3 level of context, the model fell short at 8.9 and GPT-4 took its place as the highest performer at 8.9. The lowest performer in this was GPT-3.5 at 8.5 which consistently scored lower than all the other models across the whole test. Without any context, it was expected that the GPT-o1 model would be the best performer, it is notable though GPT-4 prevailed above GPT-o1 when given detailed contextual information on how to respond to the incident Fig 6.

5.2.4 Logical Coherence (LLM)

This metric was also measured on a scale of 1 through to 10. When asking the subject LLM to measure the level of logical coherence shown, the results are somewhat unsurprising as GPT-3.5 came in at the lowest across all context levels at 7.8. GPT-o1 performed best overall at 8.6 with the first level of context, and GPT-4o performed the most consistently across the board at an average of above 8.2, but was also second lowest. What is notable about these results is the decline in logical coherence for GPT-o1 the more context that was granted. Again, it was expected that the GPT-o1

model would prevail as the best performer in this metric, however it is once again overtaken by GPT-4 when granted stage 3 level context. What is interesting is the comparison between this, and logical coherence when measuring using natural language processing techniques. The LLM indicates that GPT-3.5 is the worst and GPT-o1 and GPT-4 are generally favourable, whereas when measuring for transitioning words in the realm of natural language processing techniques, GPT-3.5 came out as the best performer Fig 7.

6 Discussion

When observing the resulting output, it is clear that different LLMs have different qualities that could be applied to a variety of areas within cybersecurity and incident response. Due to varying degrees of LLM pre-trained data and methods for achieving a reasoned response, there is no single LLM that meets all the criteria required for every area. After looking at all of the data from the results above, and manually reviewing the responses, for real-time incident containment, isolation, eradication and recovery stages, models such as GPT-4o or GPT-3.5 emerge as strong candidates. Their responses exhibit high clarity, consistency and coherence which are essential for quick decision-making. Even though these models had an increase in verbosity in their output and were not as concise as the others, there are adjustments that could be made to different variables that may affect this measurement.

Conversely, due to their logical coherence, domain specific terminology and conciseness, when selecting an LLM to aid in preparation and post incident analysis, it may be prudent to consider GPT-o1 or GPT-4 due to their advanced reasoning capabilities. GPT-o1's ability to utilise chain-of-thought reasoning allows it to provide comprehensive and well-reasoned outputs. This extra depth in its analysis could be beneficial for identifying vulnerabilities, developing strategic defences or response routines, root cause analysis, and learning from previous incidents to then prevent future occurrences with long term security enhancements. Further within preparation stages, these models could also be used when developing training materials for an organisation's personnel, scenarios such as fire drills and helping non-technical personnel understand the context and what is happening within an incident. This further supports research conducted by Hays where research was conducted into how LLMs could be implemented in developing Incident Response Processes IRP and SOP [25].

While conducting this project, several limitations were highlighted and variable that could be experimented with that could potentially change the results found. We used a single LLM judge (GPT-4o) for all qualitative assessments, together with a fixed evaluation rubric and a constant base prompt, to promote consistency across models, scenarios, and con-

text levels. Scores for each criterion were obtained across ten runs and averaged to reduce variability. We report these qualitative results alongside quantitative indicators, namely BERTScore for consistency, a conciseness measure, and a coherence proxy to contextualise the judge ratings. This approach mitigates several sources of variability but does not remove bias entirely. Reliance on one judge model and one rubric remains a limitation, and qualitative scores may not fully capture operational correctness. Token size limits the amount of context that can be provided to an LLM, for example GPT-3.5 at the time of writing has half the context window that GPT-4 permits. One way of getting around this is by chunking the text into smaller parts, thus providing lesser amounts of data while keeping as much context as possible. In addition, our experiments relied on default model settings. Practitioners may wish to reduce temperature values to improve reproducibility in critical operational phases, or allow higher values in exploratory tasks such as scenario generation and training exercises.

6.1 Ethical Considerations

The question of ethical cyber defence is a prevalent discussion when considering the implementation of LLMs into an organisation's environment. It is the duty of an organisation to protect information and digital assets from cyber threats by implementing guidelines and procedures. For example, using a model that has high conciseness of 17.2 (Section 5.1.2) and low logical coherence of 7.8 (Section 5.2.4) such as ChatGPT 3.5 based on our results could highly likely lead to an inexperienced response and subsequently devalue the employee's growth and learning potential. Users that are not experts in the field could act confidently on false pretences without a proper chain of accountability. This results in an ethical concern in the usage of AI, not only in the way AI processes data, but also in their method of interacting with humans in the loop. On the other end of the scale, a highly logical coherent LLM tool could grant the employer a false sense of security and efficiency, which could potentially lead to lower standards of hiring and training, devaluing the middle to senior competence levels in the field.

From the offensive security side, the increased use of LLMs within cyber security raises new questions and allows for new threats to emerge to which threat actors can take advantage. There has been research conducted into threat actors taking advantage of the generative nature of LLMs. Glorin identifies a number of threats such as social engineering attacks, data leakages, identity theft, phishing attacks and malware threats. In order to mitigate such threats, organisations need to consider carrying out reassessments of security measures, threat models and risk assessments to attempt to mitigate potential attack vectors [33]. Besides already existing regulations surrounding computer security

such as General Data Protection Regulation (GDPR), the cyber resilience act and the Network and Information Security Directive, there is a new regulation governing the use of AI called the EU AI act. The EU AI act adopts a risk-based approach, defining AI systems and categorising them into different risk levels: minimal, limited, high and unacceptable. There are strict requirements in place for those systems or applications that are considered high risk, which incident response in this regard does not fall under, with the potential exception of incident response applications with public service and law enforcement [4].

6.1.1 Risk Mitigation

To address the identified risks, we recommend implementing a human-in-the-loop model with analyst approval for high-impact actions and dual control for irreversible steps. Use calibrated outputs with explicit confidence scores and allow abstention below a defined threshold. Require evidence and provenance for claims, especially when retrieval is used, and introduce models in stages through shadow and advisory modes before limited automation. Maintain expertise through regular exercises without model assistance and post-incident reviews that assess human reasoning. Strengthen governance by pinning model versions, keeping full audit logs of prompts, context and actions, and recording where model outputs influenced decisions. Reduce operational risk through least-privilege access, segregation of duties for approvals and execution, continuous evaluation of disagreement and intervention rates, latency and error corrections, and periodic red teaming. Protect data by minimizing shared information, applying redaction and retention limits, and preferring private or on-premise inference for sensitive workloads.

7 Conclusion

Our study examined the application of LLM models in cybersecurity incident response. Experiments indicated that GPT-4o and GTP-3.5 are effective for real-time tasks such as containment, isolation, and recovery due to their clarity and consistency. Alternatively, GPT-o1 and GPT-4 demonstrated strong analytical and reasoning capabilities suitable for preparation, vulnerability assessments, post-incident analysis, and creating targeted training scenarios.

The practical applicability of these models highlights opportunities and limitations for organizations integrating AI into their incident response workflows. Ethically, reliance on AI introduces risks, including the potential erosion of human expertise and critical thinking within security teams. Furthermore, increased AI adoption in cybersecurity may open new

vectors for threats, requiring organizations to reassess their security frameworks and consider regulatory implications.

Future research could further assess other generative AI models, including locally hosted alternatives, and experiment with RAG and iterative query methods to enhance performance. Additional studies can also examine varied input

formats that involve manual human inputs to replicate realistic conditions, employ quantitative metrics such as mean response time, and evaluate qualitative aspects like response usability through tailored scenarios and runbooks.

A Appendix

Table 1 Complete experimental metrics table

	Clarity	Relevance	Logical Coherence	Domain-Specific Terminology	BERTScore	Conciseness	Coherence
3.5_stage_1	8.96	8.77	7.8	8.55	0.4201	17.236	26.81
3.5_stage_2	8.95	8.84	7.86	8.61	0.4938	17.892	27.514
3.5_stage_3	8.89	8.77	7.88	8.57	0.4511	17.191	27.362
4_stage_1	9.01	9.025	8.6067	9.02	0.3277	16.168	27.087
4_stage_2	8.8105	8.8788	8.3075	8.7999	0.3258	14.696	24.267
4_stage_3	8.9667	8.965	8.3883	8.9783	0.3326	15.084	25.039
4o_stage_1	9.04	8.94	8.24	8.85	0.3568	17.992	26.801
4o_stage_2	8.92	8.95	8.22	8.86	0.382	18.506	27.212
4o_stage_3	9.01	9.03	8.29	8.9	0.3694	18.484	27.605
o1_stage_1	8.85	9.1483	8.625	9.1667	0.3391	15.976	23.482
o1_stage_2	8.8663	9.0718	8.5342	9.2432	0.3394	17.402	25.035
o1_stage_3	8.8333	8.98	8.3167	8.915	0.3317	15.976	23.482

Author Contributions Conceptualization, G.J., D.K., N.P., R.M.; methodology, G.J.; software, G.J.; validation, N.P., R.M.; data curation, G.J.; writing—original draft preparation, G.J., D.K.; writing—review and editing, D.K., N.P., R.M.; supervision, N.P., R.M., W.J.B. All authors have read and agreed to the published version of the manuscript.

Data Availability Dataset available upon reasonable request from the authors.

Declarations

Competing interests The authors declare no competing interests.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adaptation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit <http://creativecommons.org/licenses/by/4.0/>.

References

- Naseer, A., Naseer, H., Ahmad, A., Maynard, S.B., Siddiqui, A.M.: Real-time analytics, incident response process agility and enterprise cybersecurity performance: a contingent resource-based analysis. *International Journal of Information Management* **59**, 102334 (2021). <https://doi.org/10.1016/j.ijinfomgt.2021.102334>
- Jada, I., Mayayise, T.O.: The impact of artificial intelligence on organisational cyber security: an outcome of a systematic literature review. *Data and Information Management* **8**, 100,063 (2024). <https://doi.org/10.1016/J.DIM.2023.100063>
- Turing, A.: *Intelligent Machinery* (1948), pp. 395–432. Oxford University Press/Oxford (2004). <https://doi.org/10.1093/oso/9780198250791.003.0016> (<https://academic.oup.com/book/42030/chapter/355746030>)
- EU: Artificial intelligence act (2024)
- Ahmad, A., Maynard, S.B., Desouza, K.C., Kotsias, J., Whitty, M.T., Baskerville, R.L.: How can organizations develop situation awareness for incident response: a case study of management practice. *Computers and Security* **101**, 102122 (2021). <https://doi.org/10.1016/j.cose.2020.102122>
- Cichonski, P., Millar, T., Grance, T., Scarfone, K.: *Computer security incident handling guide: Recommendations of the national institute of standards and technology* (2012)
- He, Y., Zamani, E.D., Lloyd, S., Luo, C.: Agile incident response (air): improving the incident response process in healthcare. *International Journal of Information Management* **62**, 102435 (2022). <https://doi.org/10.1016/j.ijinfomgt.2021.102435>
- Kotsias, J., Ahmad, A., Scheepers, R.: Adopting and integrating cyber-threat intelligence in a commercial organisation. *Eur. J. Inf. Syst.* **32**, 35–51 (2023). <https://doi.org/10.1080/0960085X.2022.2088414>
- Feuerriegel, S., Hartmann, J., Janiesch, C., Zschech, P.: Generative ai. *Business & Information Systems Engineering* **66**(1), 111–126 (2024)
- Teubner, T., Flath, C.M., Weinhardt, C., Van Der Aalst, W., Hinz, O.: Welcome to the era of chatgpt et al. the prospects of large language models. *Business & Information Systems Engineering* **65**(2), 95–101 (2023)
- Wang, R., Chen, Z.S.: Large-scale foundation models and generative ai for bigdata neuroscience. *Neurosci. Res.* **215**, 3–14 (2025)
- Clusmann, J., Kolbinger, F.R., Muti, H.S., Carrero, Z.I., Eckardt, J.N., Laleh, N.G., Löffler, C.M.L., Schwarzkopf, S.C., Unger, M., Veldhuizen, G.P., et al.: The future landscape of large language models in medicine. *Communications medicine* **3**(1), 141 (2023)
- Kocoń, J., Cichecki, I., Kaszyca, O., Kochanek, M., Szydło, D., Baran, J., Bielaniec, J., Gruza, M., Janz, A., Kanclerz, K., et al.: Chatgpt: jack of all trades, master of none. *Information Fusion* **99**, 101,861 (2023)
- Scott, J., Kyobe, M.: Trends in cybersecurity management issues related to human behaviour and machine learning. In: *International Conference on Electrical, Computer, and Energy Technologies, ICECET 2021*. Institute of Electrical and Electronics Engineers Inc. (2021). <https://doi.org/10.1109/ICECET52533.2021.9698626>
- Rege, M., Mbah, R.B.K.: Machine learning for cyber defense and attack. *Data Analytics* **2018**, 83 (2018)
- Noever, D.: Can large language models find and fix vulnerable software? (2023)
- Cheshkov, A., Zadorozhny, P., Levichev, R.: Evaluation of chatgpt model for vulnerability detection. *arXiv:2304.07232* (2023)
- Marvin, G., Hellen, N., Jjing, D., Nakatumba-Nabende, J.: Prompt engineering in large language models. In: *International Conference on Data Intelligence and Cognitive Informatics*, pp. 387–402. Springer (2023)
- Naveed, H., Khan, A.U., Qiu, S., Saqib, M., Anwar, S., Usman, M., Akhtar, N., Barnes, N., Mian, A.: A comprehensive overview of large language models. *ACM Transactions on Intelligent Systems and Technology* (2023)
- Lo, L.S.: The clear path: a framework for enhancing information literacy through prompt engineering. *Journal of Academic Librarianship* **49**, 102720 (2023). <https://doi.org/10.1016/j.acalib.2023.102720>
- Lewis, P., Perez, E., Piktus, A., Petroni, F., Karpukhin, V., Goyal, N., Küttler, H., Lewis, M., Yih, W.T., Rocktäschel, T., Riedel, S., Kiela, D.: Retrieval-augmented generation for knowledge-intensive nlp tasks (2020). <https://github.com/huggingface/transformers/blob/master/>
- Solaiman, I., Brundage, M., Jack, O., Openai, C., Openai, A.A., Herbert-Voss, A., Openai, J.W., Openai, A.R., Openai, G.K., Wook, J., Openai, K., Kreps, S., Politowatch, M.M., Newhouse, A., Blazakis, J., McGuffie, K., Wang, J.: Openai report release strategies and the social impacts of language models (2019)
- Gao, Y., Xiong, Y., Gao, X., Jia, K., Pan, J., Bi, Y., Dai, Y., Sun, J., Wang, H., Wang, H.: Retrieval-augmented generation for large language models: A survey. **2**(1) (2023) *arXiv:2312.10997*
- Cuconasu, F., Trappolini, G., Siciliano, F., Filice, S., Campagnano, C., Maarek, Y., Tonello, N., Silvestri, F.: The power of noise: Redefining retrieval for rag systems. In: *Proceedings of the 47th International ACM SIGIR Conference on Research and Development in Information Retrieval*, pp. 719–729 (2024)
- Hays, S., White, J.: Employing llms for incident response planning and review. *arXiv:2403.01271* (2024)
- Liu, Z.: Autobnb: Multi-agent incident response with large language models. In: *2025 13th International Symposium on Digital Forensics and Security (ISDFS)*, pp. 1–6. IEEE (2025)
- Brown, T., Mann, B., Ryder, N., Subbiah, M., Kaplan, J.D., Dhariwal, P., Neelakantan, A., Shyam, P., Sastry, G., Askell, A., et al.: Language models are few-shot learners. *Adv. Neural. Inf. Process. Syst.* **33**, 1877–1901 (2020)

28. Lo, L.S.: The clear path: a framework for enhancing information literacy through prompt engineering. *The Journal of Academic Librarianship* **49**(4), 102,720 (2023)
29. Zhang, T., Kishore, V., Wu, F., Weinberger, K.Q., Artzi, Y.: Bertscore: Evaluating text generation with bert. [arXiv:1904.09675](https://arxiv.org/abs/1904.09675) (2019)
30. Mouratidis, H., Islam, S., Santos-Olmo, A., Sanchez, L.E., Ismail, U.M.: Modelling language for cyber security incident handling for critical infrastructures. *Computers & Security* **128**, 103,139 (2023)
31. explosion: spacy: Industrial-strength nlp. <https://github.com/explosion/spaCy> (2025)
32. Zheng, L., Chiang, W.L., Sheng, Y., Zhuang, S., Wu, Z., Zhuang, Y., Lin, Z., Li, Z., Li, D., Xing, E., et al.: Judging llm-as-a-judge with mt-bench and chatbot arena. *Adv. Neural. Inf. Process. Syst.* **36**, 46595–46623 (2023)
33. Sebastian, G.: Do chatgpt and other ai chatbots pose a cyber-security risk? *International Journal of Security and Privacy in*

Pervasive Computing **15**, 1–11 (2023). <https://doi.org/10.4018/ijspcc.320225>

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.